

OPERATOR

Eswar Mahalingam

ROLE

Blue Team Operator & Trainee

RANK

Officer Candidate

CREDENTIAL ID

GS-STU-DSOU-2026-039A

REPORTS TO

Ritik Shrivastava

ISSUED

09 Sep 2026

VALID UNTIL

08 Mar 2027

● DETECTION SHIPPED

● RULE VALIDATED

● REPORT DELIVERED

Incident Detection Report — CVE-2026-59310

1. Executive Summary

A path-traversal-to-RCE weakness in vCenter's rsyslog handling (lab scenario CVE-2026-59310) lets a crafted syslog hostname write a cron job into `/etc/cron.d/`, which then executes as root. I researched the issue with AI-assisted tooling, engineered a Sigma detection rule, validated it with a safe attack simulation, and compiled this report for the CISO.

SCOPE NOTE

Conducted in the GraySentinel lab against target 192.168.1.50. The CVE identifier and its sibling IDs are lab scaffolding — verify against the real vendor advisory before any production action.

2. Attack Path (observed in lab)

- Attacker sends a syslog message with traversal sequences (`../`) in the hostname field.
- rsyslog writes attacker-controlled content into `/etc/cron.d/`.
- The dropped cron entry runs as root → remote code execution and persistence.

MITRE ATT&CK: T1053.003 (Scheduled Task/Job: Cron) · Initial Access via an exposed logging service.

3. Detection Engineering

The deliverable is a three-tripwire Sigma rule (`detection/detection-rule.sigma`) that alerts if ANY condition fires — catching the attack before and after it succeeds:

TRIPWIRE	SIGNAL	CATCHES
Traversal indicator	<code>../</code> or <code>..%2f</code> in syslog message	the attempt
Cron write	auditd openat (syscall 257) into <code>/etc/cron.d/</code>	the persistence outcome
rsyslog child shell	rsyslogd spawning <code>/sh</code> or <code>/bash</code>	the RCE moment

False positives are tuned out: config-management writes to `/etc/cron.d/` and benign rsyslog templates containing `../`.

Why layered: a single rule that only watches the cron file misses the attack until it has already succeeded. Firing on the traversal attempt as well gives the SOC a chance to respond before root code runs, and the rsyslog-child-shell signal is a high-fidelity backstop if the first two are evaded.

Key indicators to hunt for

- `../` or `..%2f` appearing in a syslog hostname or message field.
- New or modified files under `/etc/cron.d/` that are not tied to a change ticket.

OPERATOR

Eswar Mahalingam

ROLE

Blue Team Operator & Trainee

RANK

Officer Candidate

CREDENTIAL ID

GS-STU-DSOU-2026-039A

REPORTS TO

Ritik Shrivastava

ISSUED

09 Sep 2026

VALID UNTIL

08 Mar 2027

DETECTION SHIPPED

RULE VALIDATED

REPORT DELIVERED

Validation, Recommendations & Next Steps

4. Validation

Simulated the technique with atomic-operator (--test, Atomic Red Team) against 192.168.1.50 — a known-benign replay of the attack behaviour, not a live exploit. Result: the rule triggered as expected, establishing detection confidence and closing the detect-test loop.

5. Recommendations

- Patch vCenter to the fixed build once the real advisory is confirmed.
- Harden — restrict inbound syslog to trusted hosts; run rsyslog least-privilege.
- Monitor — deploy the Sigma rule to the SIEM and alert at critical.
- Verify field names (ParentProcessName / ppid) against the real log pipeline.
- Broaden coverage — add vpxd / appliance logs, not just Linux-host auditd.

6. Next Steps

Confirm the CVE against the vendor advisory, test the rule on production telemetry, and schedule periodic atomic re-tests to prevent detection drift.

7. Integrity & Method

Every action in this mission was performed inside a self-contained training sandbox. This report — and the repository it ships in — publishes only the defensive outputs: the Sigma detection rule and this incident report. No exploit code, payload, or weaponized module is included, which is also the correct scope for a CISO-facing document.

The six lab phases in order: (1) AI intelligence gathering, (2) a scanner CHECK module for verification, (3) GDB/GEF process inspection, (4) authoring the Sigma rule, (5) atomic-operator validation, (6) this report. The detection rule in phase 4 is the substantive Blue Team output; phases 1–3 and 5 are lab-scripted steps that produced canned output.

8. Skills Demonstrated

AREA	EVIDENCE
Threat research	AI-assisted CVE research + strategy synthesis
Detection engineering	3-layer Sigma rule, ATT&CK-mapped, FP-tuned
Validation	Atomic Red Team replay confirming rule fires
Security reporting	Executive-ready incident report for the CISO